06 — Accord de traitement des données (sous-traitance)

English: ../en/06-data-processing-agreement.md

> **MODÈLE — À FAIRE VALIDER.** Annexe B des Conditions de service SaaS (modèle 02).

Cartouche	
Juridiction	RDC — Code du numérique, Livre III (responsable de traitement, sous-traitant, sécurité, transferts)
Hypothèses	H-03 (Nhill sous-traitant des données des établissements), H-04 (hébergement), H-05 (autorité), H-14 (conservation), H-15 (violation)
Sources	S01, S07, S16 — voir 00-recherche-juridique.md § 7
Clauses à valider	V-05, V-06, V-07
Version	[NUMÉRO] du [DATE]

1. Parties et rôles

Le **Client** (l'établissement) est responsable du traitement des données qu'il enregistre dans Nhill. L'**Éditeur** ([RAISON SOCIALE]) agit comme sous-traitant : il traite ces données uniquement pour fournir le Service et selon les instructions documentées du Client, que constituent le contrat, le présent accord et les réglages faits dans l'application.

2. Description du traitement

Élément	Contenu
Objet	gestion commerciale et caisse : ventes, achats, stock, paiements, rapports, équipe
Personnes concernées	clients et fournisseurs du Client, ses employés et utilisateurs
Données	identité et coordonnées, identifiants fiscaux des tiers, historique d'achats et de paiements, données de connexion et journal d'activité des utilisateurs
Données sensibles	**aucune n'est prévue** ; le Client s'engage à ne pas en enregistrer dans les champs libres
Opérations	enregistrement, conservation, consultation, calcul, export, suppression
Durée	durée du contrat, puis réversibilité (article 8 du modèle 02)
Lieu	[PAYS / RÉGION DE L'HÉBERGEMENT]

3. Obligations de l'Éditeur

1. Ne traiter les données que sur instruction du Client ; l'informer si une instruction lui semble contraire à la loi.
2. Garantir la confidentialité : personnel habilité, engagé à la confidentialité, accès limité aux besoins de l'assistance et de l'exploitation.
3. Mettre en œuvre les mesures de sécurité de l'article 6.
4. Ne pas recourir à un autre sous-traitant sans information préalable du Client (article 5).

5. Aider le Client à répondre aux demandes d'exercice des droits (exports, rectification par le Client lui-même dans l'application).
6. Notifier au Client toute violation de données le concernant **dans les meilleurs délais et au plus tard [24] heures** après en avoir pris connaissance, avec les informations disponibles (nature, catégories et volume approximatif, conséquences probables, mesures prises), pour permettre au Client de notifier l'autorité dans le délai légal **[À VALIDER : V-06]**. Procédure : modèle 14.
7. Supprimer ou restituer les données à la fin du contrat (article 8 du modèle 02) et confirmer la suppression par écrit sur demande.
8. Mettre à disposition les informations nécessaires pour démontrer le respect de cet accord ; permettre un audit [une fois par an, à la charge du Client, avec préavis de 30 jours, par un auditeur tenu au secret].

4. Obligations du Client

Le Client dispose d'une base légale pour chaque traitement, informe les personnes concernées (dont ses employés : modèle 17), accomplit les formalités qui lui incombent auprès de l'autorité de protection des données, attribue les droits d'accès dans l'application et retire ceux des personnes qui le quittent.

5. Sous-traitants ultérieurs

Sous-traitant	Service	Pays	Garanties
[HÉBERGEUR, ex. Supabase Inc.]	base de données PostgreSQL	[PAYS / RÉGION]	[contrat, clauses de protection des données]
[HÉBERGEUR DU SERVEUR D'API]	serveur applicatif	[PAYS]	[ ]
[PRESTATAIRE DE PAIEMENT]	paiement de l'abonnement (pas les ventes du Client)	[PAYS]	[ ]

L'Éditeur informe le Client de tout changement [30] jours à l'avance ; le Client peut s'opposer pour un motif légitime et, à défaut d'accord, résilier sans pénalité.

6. Mesures de sécurité

- chiffrement des échanges (TLS) entre les applications et le serveur ;
- isolation des données de chaque établissement dans la base (sécurité au niveau des lignes forcée, rôle applicatif sans privilège de contournement) ;
- mots de passe hachés (Argon2id), sessions courtes avec rotation, limitation des tentatives ;
- contrôle d'accès par rôle, journal d'audit non modifiable ;
- sauvegardes chiffrées, test de restauration ;
- secrets de l'infrastructure hors du code, fichiers de configuration protégés ;
- double authentification obligatoire pour les administrateurs de la plateforme.

Ces mesures sont revues au moins une fois par an. Aucune mesure ne garantit l'absence totale de vulnérabilité.

7. Transferts hors de la RDC

Si l'hébergement est situé hors de la RDC, l'Éditeur [a obtenu / demande] l'autorisation de transfert requise ([RÉFÉRENCE]) et impose à ses sous-traitants des obligations de protection au moins équivalentes. **[À VALIDER : V-05 — régime exact, partage des formalités entre responsable et sous-traitant.]**

8. Durée

Le présent accord s’applique tant que l’Éditeur traite des données pour le Client.

Fait à [VILLE], le [DATE].

Pour l’Éditeur	Pour le Client
[NOM, FONCTION]	[NOM, FONCTION]